

Contents

1	FUT01: 認証・セキュリティ強化	1
1.1	0. 文書情報	1
1.2	1. 概要	1
1.3	2. 関連要件・候補	1
1.3.1	2.1 要件候補 (将来 FR)	1
1.3.2	2.2 基本設計論点	2
1.3.3	2.3 詳細設計バックログ	2
1.4	3. 影響範囲	3
1.5	4. 実施条件	4
1.6	5. 関連設計	4
1.7	6. 未確定事項・確認事項	4

1 FUT01: 認証・セキュリティ強化

1.1 0. 文書情報

項目	内容
文書名	FUT01: 認証・セキュリティ強化
将来対応 ID	FUT-01
対象システム	FAQ AI ウィジェット SaaS / メインシステム
作成日	2026-05-17
版数	v1.0
ステータス	検討中 (MVP 外)

1.2 1. 概要

項目	内容
概要	MVP では補完策 (パスワード再入力、ロックアウト、Turnstile、操作通知、監査ログ、DB 操作者制限・月次棚卸し・全クエリ監査) でリスク受容している認証・セキュリティ領域について、Post-MVP で MFA / 列単位暗号化 / SSO・パスキーを順次強化する。
背景	単一プラン・最小構成での MVP リリース後、限定公開～GA フェーズで利用者側の認証強度・チャット本文の機密性・運営者操作の二重承認をエンタープライズ水準まで引き上げる必要がある。
期待効果	アカウント乗っ取りリスクの低減、個別チャット本文漏洩時の影響範囲限定、特権操作の証跡強化、エンタープライズ契約獲得余地の拡大。
優先度 (将来対応内)	高
想定時期	T2(ベータ判定まで)～T3(GA 判定まで)

1.3 2. 関連要件・候補

1.3.1 2.1 要件候補 (将来 FR)

1.3.1.1 認証・セキュリティ

ID	要件候補	MVP の前提	判定時期	判定基準 / 完了条件
FUT-REQ-SEC-001	個別チャット本文の列単位暗号化	平文保存 + DB 操作者 2 名以下・月次棚卸し・全クエリ監査の補完策	GA	AES-256-GCM + オーナー派生による列単位暗号化方式が承認され、staging 復元 E2E スモークが合格すること

ID	要件候補	MVP の前提	判定時期	判定基準 / 完了条件
FUT-REQ-SEC-002	利用者側 admin / operator MFA	パスワード再入力、ロックアウト、Turnstile、操作通知、監査ログでリスク受容	限定公開 / ベータ / GA	限定公開で admin opt-in、ベータで契約単位強制可、GA で新規契約既定 ON とするか判定
FUT-REQ-SEC-003	4-eyes 原則の完全強制	3 操作をハードゲート化し、7 操作は承認ログのみ	ベータ / GA	ベータで全 10 操作ワークフロー化、GA でバイパス禁止。SCR-096 の承認バイパス検出 KPI が 4 週間連続 0 件
FUT-REQ-SEC-004	運営者サブロール分割	単一 service_operator ロール (利用者側は MVP v2.6 で 3 ロール制 (オーナー / プロジェクト管理者 / メンバー) に整理済み。本項は運営者ロール側の分割のみを扱う)	Post-MVP	運営者人数、職務分掌要件、内部統制レビュー、サポート運用の分離ニーズで導入可否を判定
FUT-REQ-SEC-005	SSO / ソーシャルログイン / パスキー	自前アカウント + パスワード + メール確認	Post-MVP	エンタープライズ要望、認証リスク低減効果、サポート負荷をもとに判定
FUT-REQ-SEC-006	データ保持期間の利用者側調整 UI (短縮 / 長期化)	MVP は NFR-702 によりシステム固定値で固定し UI を提供しない。短縮はサポート窓口経由の運営者対応、長期化は契約調整 (運営者側 FUT) で対応	Post-MVP	エンタープライズ顧客のコンプライアンス要件・契約条項としてのデータ保持カスタマイズ需要、運営者側の長期化承認フロー整備、電子帳簿保存法等の法定下限を下回らないガード設計を踏まえて再開判定

1.3.2 2.2 基本設計論点

1.3.2.1 認証・セキュリティ

項目	基本設計で具体化すること	関連 Future 要件
利用者側 admin / operator MFA	SCR-028 アカウント設定、MFA 登録・解除フロー、契約単位強制状態、未設定ユーザーのログイン制御、リカバリ導線	FUT-REQ-SEC-002
4-eyes 完全強制	10 操作の申請・承認・実行状態、SCR-096 のバイパス検出 KPI、緊急例外 RB-014 との分岐	FUT-REQ-SEC-003
運営者サブロール分割	権限マトリクス、メニュー表示制御、API 認可境界、監査ログの role / subrole 記録粒度	FUT-REQ-SEC-004
SSO / パスキー	認証プロバイダ選定、既存自前認証との併存、招待・退会・ロックアウトとの状態整合	FUT-REQ-SEC-005
個別チャット列単位暗号化	階層、検索・復元・監査への影響、障害時の復旧設計、運用者が本文を扱う導線の制限	FUT-REQ-SEC-001

1.3.3 2.3 詳細設計バックログ

1.3.3.1 契約 MFA 強制 (DDL 候補)

```

ALTER TABLE accounts
  ADD COLUMN mfa_enforcement TEXT NOT NULL DEFAULT 'off'
  CHECK (mfa_enforcement IN ('off', 'admin_only', 'all_members'));

CREATE TABLE owner_mfa_policy_audit_logs (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL,
  changed_by TEXT NOT NULL,
  before_policy TEXT NOT NULL,
  after_policy TEXT NOT NULL,
  reason TEXT,
  created_at TEXT NOT NULL
);

```

1.3.3.2 個別チャット本文の列単位暗号化 (DDL 候補)

```
ALTER TABLE chat_messages
  ADD COLUMN body_ciphertext BLOB,
  ADD COLUMN body_nonce TEXT,
  ADD COLUMN body_key_version INTEGER;

CREATE TABLE owner_key_versions (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL,
  key_version INTEGER NOT NULL,
  status TEXT NOT NULL,
  created_at TEXT NOT NULL,
  rotated_at TEXT,
  UNIQUE (owner_account_id, key_version),
  CHECK (status IN ('active', 'retired'))
);
```

1.3.3.3 実装設計バックログ (関連分)

ID	対象	実装設計で具体化すること	関連 Future 要件
FUT-DD-SEC-001	個別チャット列単位暗号化	暗号化カラム、派生、ローテーション、バックフィル、復元手順、検索制約、監査ログ	FUT-REQ-SEC-001
FUT-DD-SEC-002	利用者側 MFA	accounts.mfa_enforcement、MFA 登録 API、回復コード、未設定時ログイン制御、監査ログ	FUT-REQ-SEC-002

1.3.3.4 API / Worker 候補 (関連分)

領域	候補
契約 MFA	POST /api/v1/settings/mfa-policy、POST /api/v1/auth/mfa/setup、POST /api/v1/auth/mfa/recovery-code

1.3.3.5 テスト・検証候補 (関連分)

領域	検証項目
MFA	未登録ユーザーのログイン遮断、回復コード、強制 ON 変更時の既存セッション扱い、監査ログ
暗号化	key rotation、dual read、復元、検索不可項目のエラー、バックフィル再実行性

1.4 3. 影響範囲

種別	影響内容
要件	FR-005(MFA 段階導入)、NFR-319(個別チャット平文 → 暗号化)、4-eyes(3 操作ハードゲート → 全 10 操作ワークフロー)、SSO / パスキーは新規要件として追加
画面	SCR-028 アカウント設定 (MFA 登録・解除・回復コード)、ログイン画面 (MFA 入力)、招待受諾フロー (契約単位強制下)
API	POST /api/v1/settings/mfa-policy、POST /api/v1/auth/mfa/setup、POST /api/v1/auth/mfa/recovery-code、SSO 連携 OAuth / OIDC エンドポイント
テーブル	accounts.mfa_enforcement 列追加、owner_mfa_policy_audit_logs、chat_messages.body_ciphertext / body_nonce / body_key_version、owner_key_versions
運用	MFA 未設定者向けの猶予期間運用、回復コード再発行手順、ローテーション Runbook、列単位暗号化への dual read 期間運用、SSO IdP との連携運用

1.5 4. 実施条件

項目	内容
実施判断条件	限定公開での admin MFA opt-in 率 (50% 以上)、SCR-096 承認バイパス検出 KPI(4 週間連続 0 件)、AES-256-GCM 列単位暗号化方式の設計承認、staging 復元 E2E 合格
期限	T2(MFA opt-in、4-eyes 全 10 操作ワークフロー化、招待トークン期限短縮判定)、T3(MFA 契約単位強制 ON、列単位暗号化、4-eyes バイパス削除)、Post-MVP(SSO / パスキー、運営者サブロール分割)
依存関係	運営者システム側 4-eyes 完全強制 (FUT-01 運営者サブロール)、共有概念の accounts モデル拡張、PII 暗号化 (メイン正本)・暗号 管理 (メイン正本) との整合

1.6 5. 関連設計

種別	参照先
要件	../01_ 要件定義/index.md
基本設計	../02_ 基本設計/index.md
詳細設計	../03_ 詳細設計/index.md
運用設計	../04_ 運用設計/index.md
共有概念 (正本)	../共有/共有概念.md

1.7 6. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
FUT-SEC-Q-001	MFA 契約単位強制 ON 時の既存ユーザー猶予期間と通知方式	高	検討中
FUT-SEC-Q-002	個別チャット列単位暗号化の dual read 期間とバックフィル実行ウィンドウ	高	検討中
FUT-SEC-Q-003	SSO / パスキー導入時の自前アカウントとの併存方式 (同一メールでの統合可否)	中	検討中
FUT-SEC-Q-004	4-eyes 全 10 操作ワークフロー化での緊急例外 (RB-014 物理金庫) 維持可否	中	検討中